

Hashcat NTLMv2 Cracking Evidence Report

Internal Network & Active Directory Pentest Evidence Documentation

Field	Details
Test Area	Hashcat NTLMv2 cracking
Evidence Source	11-hashcat-ntlmv2-cracked.png
Result Type	Captured hash cracked
Primary Tool / Component	Hashcat
MITRE ATT&CK Mapping	T1110.002 - Brute Force: Password Cracking
Document Purpose	Professional GitHub-ready evidence report with redacted screenshot and interpretation.

This report documents one specific evidence row from the AD Network assessment. It is intentionally evidence-specific, not a generic attack tutorial. Sensitive values have been blurred or represented as redacted placeholders for safe portfolio publication.

1. Embedded Evidence Screenshot

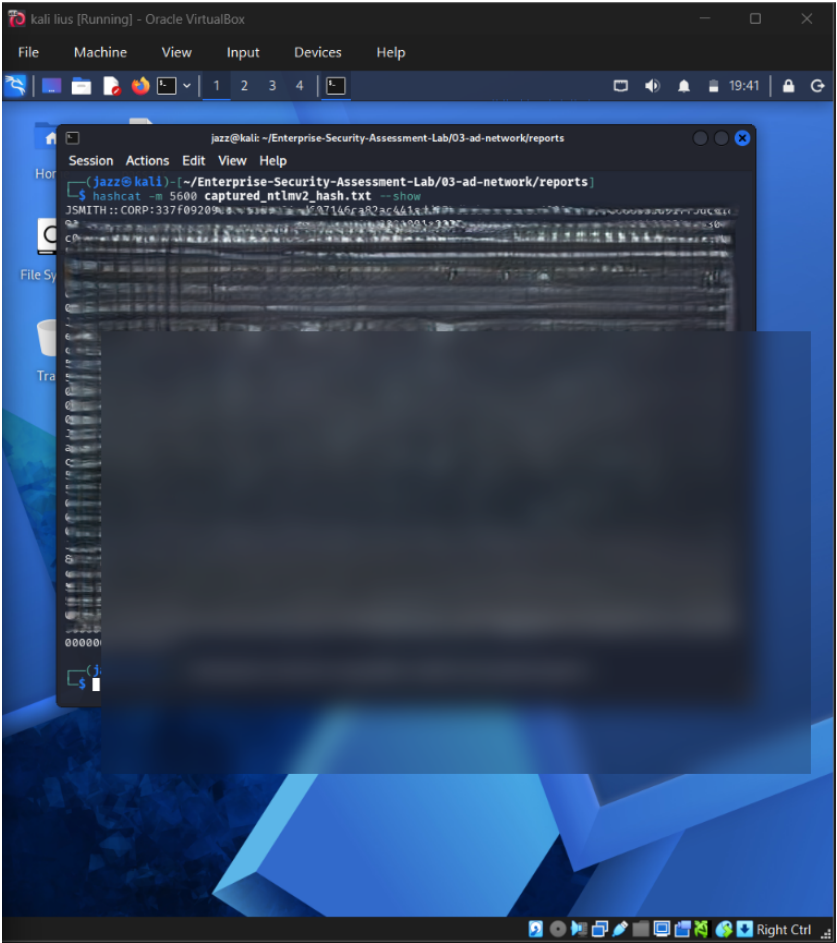


Figure 1 - Redacted evidence screenshot: 11-hashcat-ntlmv2-cracked.png

What this screenshot proves

The screenshot demonstrates Hashcat processing captured NTLMv2 material and recovering a lab password. Sensitive values and recovered secrets are blurred.

Evidence Context

Area	Value
Testing Phase	Offline Credential Risk Validation
Tool / Component	Hashcat
Objective	Validate the risk of captured NTLMv2 material by attempting offline cracking using a controlled lab wordlist.
Result Type	Captured hash cracked

2. Evidence-Specific Methodology

This section explains how this evidence fits into the overall internal network and Active Directory attack path. The goal is to demonstrate professional testing logic, not simply show a terminal screenshot.

- Export the captured NetNTLMv2 material from Responder logs.
- Select the correct Hashcat mode for NetNTLMv2.
- Run a controlled wordlist-based cracking attempt.
- Document the outcome without publishing plaintext credentials.

Command / Workflow Used

```
hashcat -m 5600 captured-netntlmv2.txt /usr/share/wordlists/rockyou.txt  
hashcat -m 5600 captured-netntlmv2.txt --show
```

Sanitized Output Style

```
<REDACTED_USER>: :CORP:<REDACTED_CHALLENGE>:<REDACTED_RESPONSE>:<REDACTED_BLOB> -> <REDACTED_PASSWORD>
```

Assessment Interpretation

The evidence supports the result type: Captured hash cracked. In a professional assessment, this evidence would be paired with the exact testing scope, timestamps, target identifiers, and remediation ownership. For GitHub publication, the report intentionally avoids showing live secrets, passwords, hashes, or reusable credential material.

3. Risk Analysis

Offline cracking bypasses online lockout controls. Once captured material is obtained, weak passwords can be recovered without generating repeated login failures against the domain.

Why this matters in enterprise AD environments

- Active Directory attacks often chain multiple medium-risk issues into domain compromise.
- Credential material, even when not plaintext, can become dangerous if cracking, relaying, or alternate authentication is possible.
- Graph-based permissions and relationship analysis is necessary because AD risk is often hidden in group nesting and delegated rights.
- Evidence must be documented clearly so defenders can connect the technical finding to a specific control gap.

Recommended Remediation

- Use long, non-dictionary passwords or passphrases.
- Deploy password filters to block common and leaked passwords.
- Monitor for credential capture and abnormal SMB authentication.
- Educate users about forced authentication attacks.
- Pair password hardening with LLMNR/NBT-NS mitigation.

Detection and Monitoring Opportunities

- Correlate authentication events with unusual source hosts and off-hours activity.
- Monitor SMB, LDAP, Kerberos, and replication-related event patterns.
- Alert on abnormal use of administrative protocols and credential dumping indicators.
- Review domain privilege assignments and privileged group membership changes regularly.

4. GitHub Publication and Redaction Guidance

This report is prepared for safe GitHub portfolio publication. The embedded screenshot has been treated as evidence, but sensitive material must not be recoverable or readable.

Sensitive Item	Action for GitHub
NTLM / NetNTLMv2 hashes	Blur or remove completely. Never publish reusable hash material.
Kerberos TGS / krb5tgs values	Blur or replace with <REDACTED_TICKET>.
Plaintext passwords	Do not publish. Replace with <REDACTED_PASSWORD>.
DCSync / NTDS hashes	Treat as domain compromise material and fully redact.
Internal IPs / domain names	May remain for lab context, but redact if privacy is required.
Username / service accounts	Keep only if lab-only; otherwise redact or generalize.

Suggested GitHub Link

[Open Report](./reports/evidence/02-hashcat-ntlmv2-cracking-evidence-report.pdf)

Professional Note

This document should be stored with the AD Network module reports, preferably under 03-ad-network/reports/evidence/. It is designed to replace a plain screenshot filename in the Evidence-Based Testing Summary table with a professional clickable report.